Corso: Cybersecurity Analyst
Modulo: W12D4 (Pratica)
Studente:Emanuele cestari
Data: 26/03/2026

1. Introduzione

L'obiettivo di questa attività era eseguire una scansione completa del target Metasploitable, individuare alcune vulnerabilità critiche, implementare misure di remediation e, infine, verificare l'efficacia degli interventi tramite una nuova scansione. Oltre a rilevare le vulnerabilità, l'obiettivo principale era dimostrare la capacità di interpretare i risultati del vulnerability assessment, comprendere l'esposizione dei servizi e ridurre concretamente la superficie di attacco del sistema.

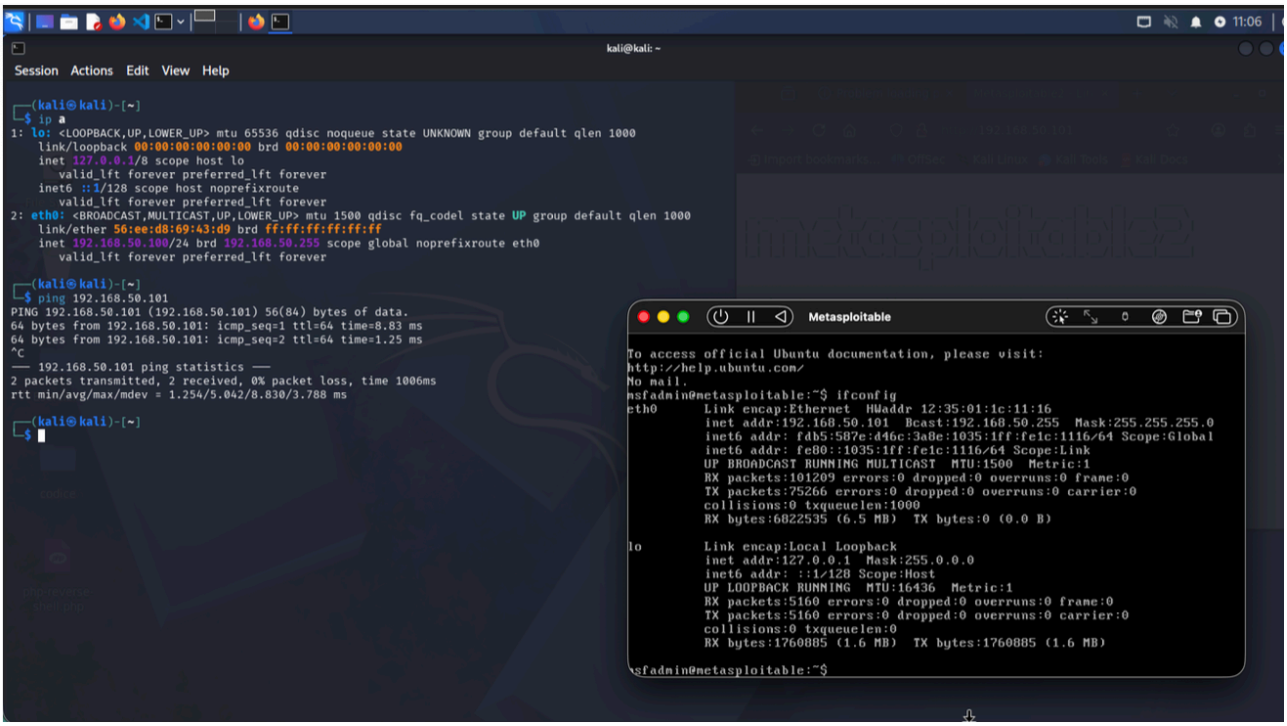
2. Ambiente di laboratorio

Questa sezione fornisce una breve descrizione del laboratorio utilizzato per l'esperimento. I dettagli sono riportati di seguito:
- Macchina attaccante: Kali Linux
- Indirizzo IP di Kali Linux: 192.168.50.100
- Macchina target: Metasploitable
- Indirizzo IP di Metasploitable: 192.168.50.101
- Tipo di rete tra le macchine virtuali (VM): Internal Network

La connettività tra le macchine è stata confermata eseguendo un ping e successivamente enumerando i servizi di rete esposti dalla macchina target.

Figura 1:

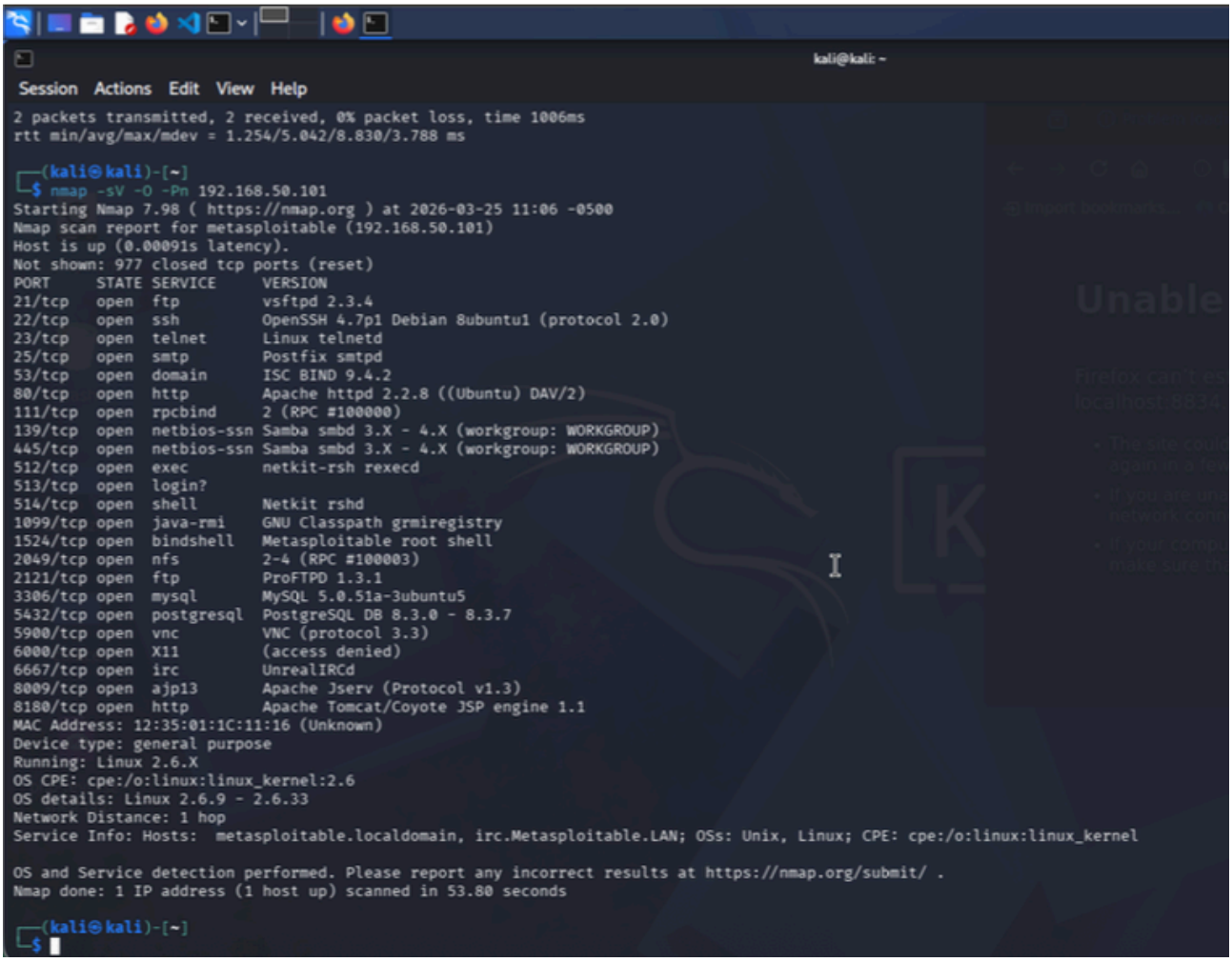
- Output di "ip a" su Kali Linux
- Output di "ifconfig" o "ip a" su Metasploitable
- Ping riuscito da Kali Linux a Metasploitable



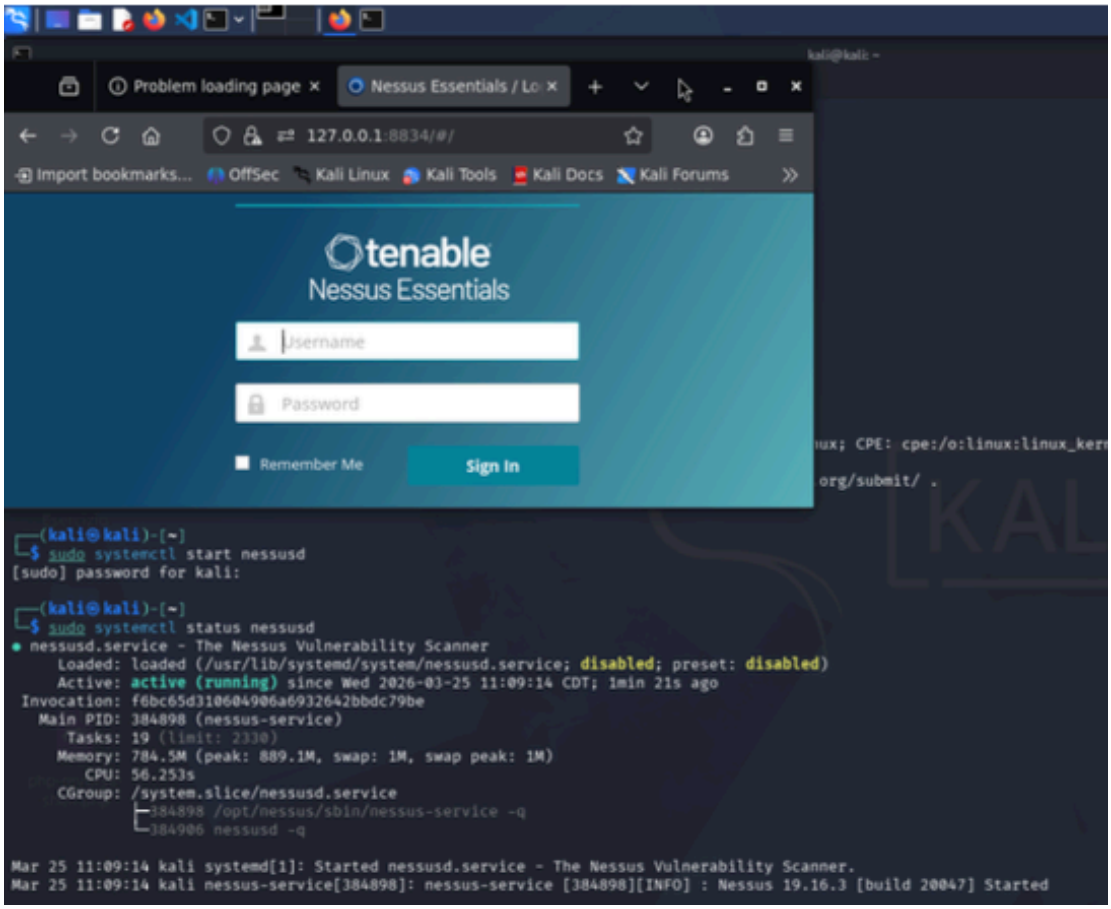
3. Fase 1 – Scansione iniziale e analisi del target
La prima fase del lavoro è consistita nell'eseguire una ricognizione iniziale del target per individuare servizi attivi, porte aperte e vulnerabilità associate.
Per ottenere una prima visione tecnica del sistema, è stata effettuata una scansione con Nmap, utile per identificare le porte esposte e i relativi servizi. Successivamente è stata eseguita una scansione completa con Nessus, utilizzata come baseline iniziale del vulnerability assessment.

3.1 Enumerazione iniziale con Nmap

Comando utilizzato:
nmap -sV -O -Pn <IP_TARGET>
Questo comando ha permesso di:
• identificare i servizi in ascolto
• determinare le versioni dei software esposti
• ottenere un'indicazione del sistema operativo
• costruire una base tecnica utile a supportare i risultati di Nessus
Figura 2: Output della scansione Nmap iniziale



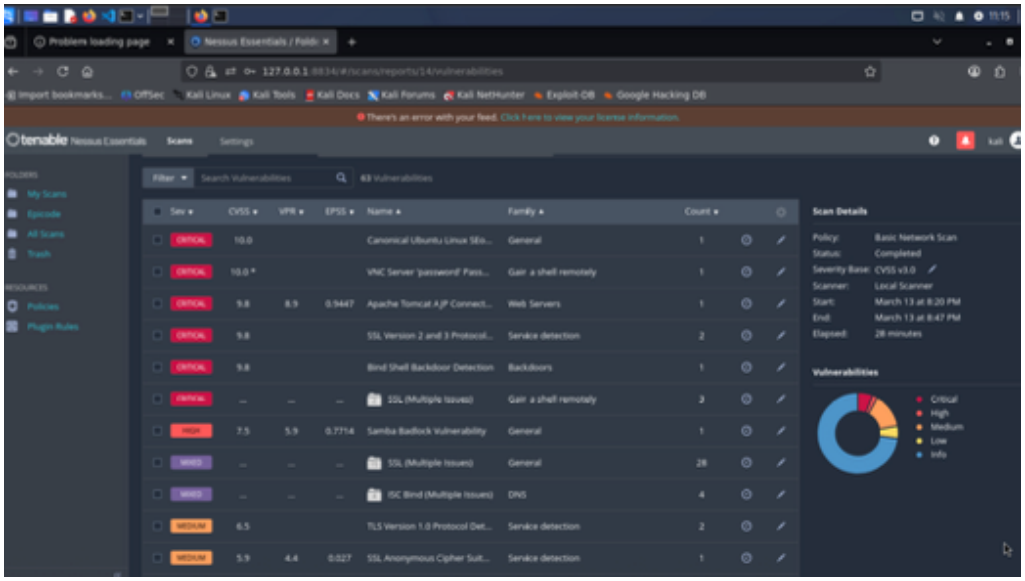
3.2 Scansione iniziale con Nessus



La scansione Nessus iniziale ha costituito il punto di partenza per identificare le vulnerabilità presenti sul target. Questa fase ha fornito la baseline per tutti gli interventi di remediation successivi, che sono stati confrontati con i risultati ottenuti in questa scansione.

Durante l'analisi sono state individuate diverse vulnerabilità, tra cui alcune di severità critica. Tra queste, quattro vulnerabilità/servizi esposti sono stati selezionati per essere mitigati durante l'attività pratica.

Figura 3: Panoramica della scansione Nessus iniziale (sopra)
Figura 4: Grafico della severità iniziale, elenco delle vulnerabilità critiche



4. Vulnerabilità selezionate per la remedia>on

Dopo l'analisi iniziale, sono state selezionate le seguenti esposizioni/vulnerabilità per la fase di remediation:

1. VNC Server "password" Password
2. Bind Shell Backdoor Detection
3. Apache Tomcat AJP Connector Exposure
4. PostgreSQL Exposed Service / Service Hardening

La scelta è stata effettuata considerando tre criteri principali:

• impatto sulla sicurezza
• facilità di dimostrazione tecnica
• possibilità di verificare chiaramente il miglioramento nella scansione finale

5. Fase 2 – Remedia>on delle vulnerabilità

In questa fase sono stati applicati interventi pratici di hardening e riduzione della superficie di attacco. Ogni remediation è stata accompagnata da una verifica tecnica per dimostrare che il servizio vulnerabile fosse effettivamente disabilitato, bloccato o non più sfruttabile.

5.1 Vulnerabilità 1 – VNC Server "password" Password

Descrizione tecnica:
La scansione iniziale ha evidenziato la presenza di un servizio VNC attivo sul target. Il servizio risultava esposto e associato a una configurazione debole/insicura, rappresentando quindi una criticità rilevante.
Obiettivo della remediation:
Disabilitare il servizio VNC per impedire accessi remoti non autorizzati e rimuovere l'esposizione del servizio sulla porta dedicata.
Attività eseguite:

• Identificazione del processo VNC in esecuzione
• Verifica della porta esposta (5900)
• Terminazione dei processi collegati a VNC
• Disabilitazione dello startup script per evitare il riavvio automatico del servizio

Comandi utilizzati (adatta se necessario ai tuoi screenshot):
ps aux | grep -i vnc
sudo netstat -tulnp | grep 590
sudo pkill -f Xtightvnc
sudo pkill -f xstartup
sudo pkill -f "/root/.vnc"
sudo mv /root/.vnc/xstartup /root/.vnc/xstartup.bak

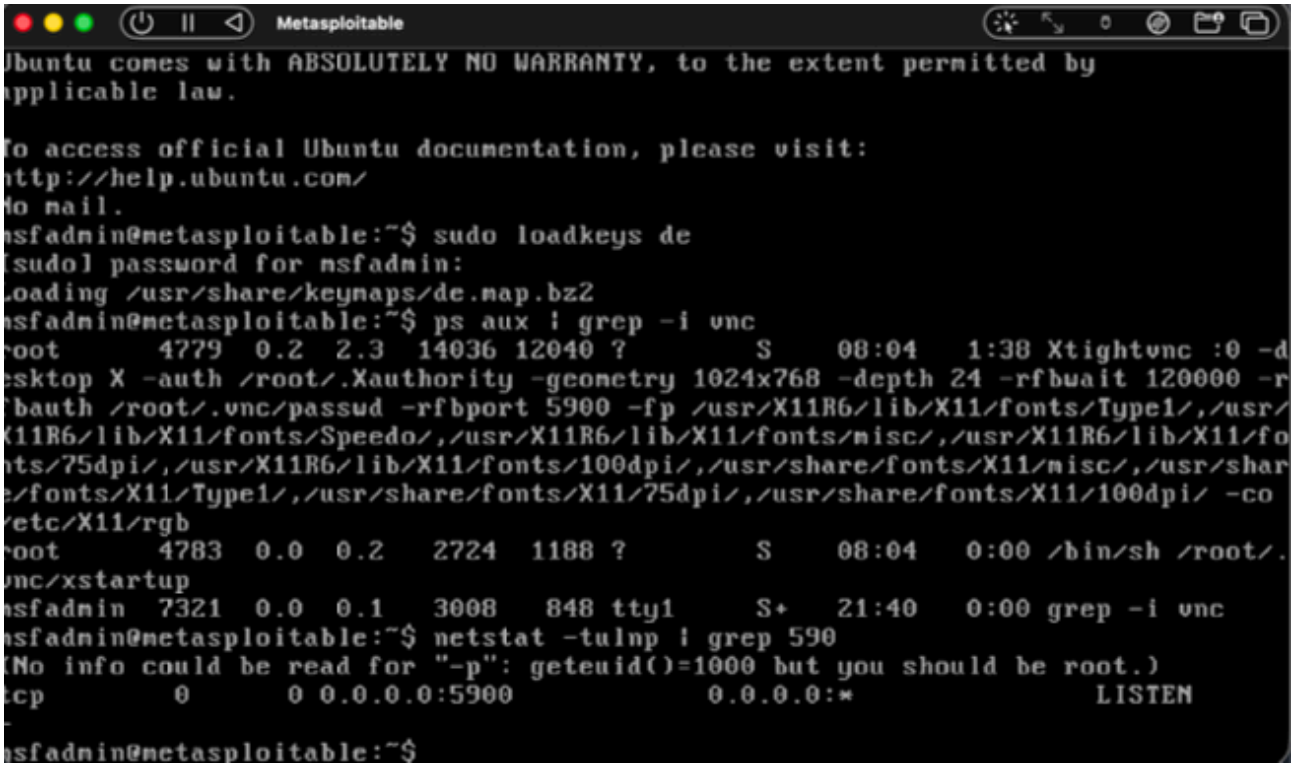


Figura 5: VNC attivo – processo trovato porta 5900 aperta

```
Metasploitable
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ sudo loadkeys de
[sudo] password for msfadmin:
Loading /usr/share/keymaps/de.map.bz2
msfadmin@metasploitable:~$ ps aux | grep -i vnc
root      4779  0.2  2.3  14036 12040 ?        S    08:04   1:38 Xtightvnc :0 -d
esktop X -auth /root/.Xauthority -geometry 1024x768 -depth 24 -rfbwait 120000 -r
fbauth /root/.vnc/passwd -rfbport 5900 -fp /usr/X11R6/lib/X11/fonts/Type1/,/usr/
X11R6/lib/X11/fonts/Speedo/,/usr/X11R6/lib/X11/fonts/misc/,/usr/X11R6/lib/X11/fo
nts/75dpi/,/usr/X11R6/lib/X11/fonts/100dpi/,/usr/share/fonts/X11/misc/,/usr/shar
e/fonts/X11/Type1/,/usr/share/fonts/X11/75dpi/,/usr/share/fonts/X11/100dpi/ -co
/etc/X11/rgb
root      4783  0.0  0.2   2724  1188 ?        S    08:04   0:00 /bin/sh /root/.
vnc/xstartup
msfadmin  7321  0.0  0.1   3008   848 tty1     S+   21:40   0:00 grep -i vnc
msfadmin@metasploitable:~$ netstat -tulnp | grep 590
(No info could be read for "-p": geteuid()=1000 but you should be root.)
tcp        0      0 0.0.0.0:5900            0.0.0.0:*               LISTEN
msfadmin@metasploitable:~$
```

Figura 6: Comandi di remediation VNC e verifica finale – nessun processo VNC o porta aperta. La disattivazione del servizio VNC ha eliminato un punto di accesso remoto vulnerabile, riducendo così il rischio di compromissione del target.

```
Metasploitable
msfadmin@metasploitable:~$ sudo pkill -9 4779
msfadmin@metasploitable:~$ ps aux | grep -i vnc
root      4779  0.2  2.3  14036 12040 ?        S    08:04   1:39 Xtightvnc :0 -
esktop X -auth /root/.Xauthority -geometry 1024x768 -depth 24 -rfbwait 120000 -
fbauth /root/.vnc/passwd -rfbport 5900 -fp /usr/X11R6/lib/X11/fonts/Type1/,/usr
X11R6/lib/X11/fonts/Speedo/,/usr/X11R6/lib/X11/fonts/misc/,/usr/X11R6/lib/X11/f
nts/75dpi/,/usr/X11R6/lib/X11/fonts/100dpi/,/usr/share/fonts/X11/misc/,/usr/sha
e/fonts/X11/Type1/,/usr/share/fonts/X11/75dpi/,/usr/share/fonts/X11/100dpi/ -co
/etc/X11/rgb
root      4783  0.0  0.2   2724  1188 ?        S    08:04   0:00 /bin/sh /root/
vnc/xstartup
msfadmin  7332  0.0  0.1   3008   852 tty1     S+   21:44   0:00 grep -i vnc
msfadmin@metasploitable:~$ sudo pkill -f Xtightvnc
msfadmin@metasploitable:~$ sudo pkill -f xstartup
msfadmin@metasploitable:~$ sudo pkill -f "/root/.vnc"
msfadmin@metasploitable:~$ ps aux | grep -i vnc
msfadmin  7339  0.0  0.1   3004   824 tty1     R+   21:46   0:00 grep -i vnc
msfadmin@metasploitable:~$ sudo netstat -tulnp n| grep 590
msfadmin@metasploitable:~$ _
```

La remediation è stata considerata conclusa con successo quando il processo VNC non risultava più attivo e la porta 5900 non era più in ascolto. La **Figura 7 mostra** nmap con la porta 1524 aperta e l'accesso effettuato con netcat, a dimostrazione della sfruttabilità.

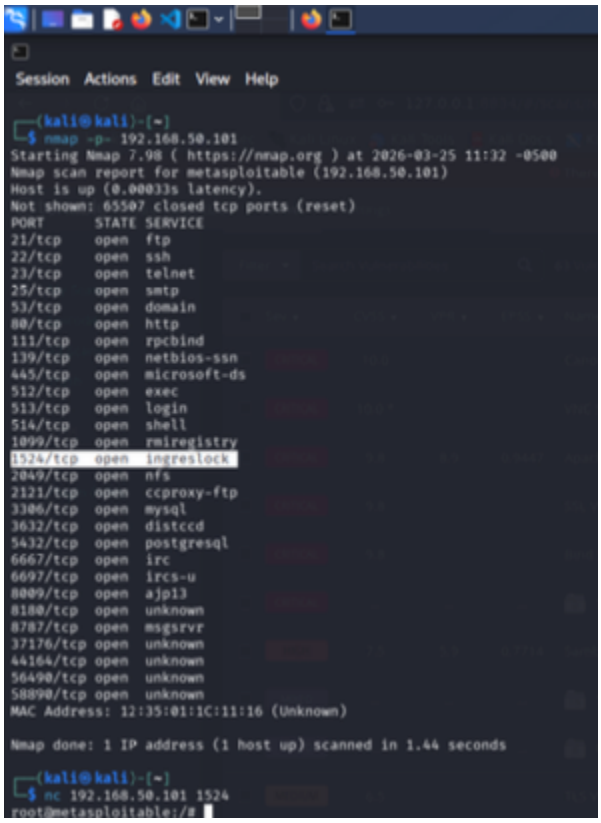


Figura 8: identificazione del servizio bind shell e applicazione della regola firewall

Figura 9: regola iptables applicata

Figura 10:

nmap finale con porta 1524 filteredCommento conclusivo sezione:

```
┌──(kali㉿kali)-[~]
└─$ nc 192.168.50.101 1524
root@metasploitable:/# nc 192.168.50.101
^C

┌──(kali㉿kali)-[~]
└─$ nc 192.168.50.101 1524
^C

┌──(kali㉿kali)-[~]
└─$ nmap -p 1524 192.168.50.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-25 11:38 -0500
Nmap scan report for metasploitable (192.168.50.101)
Host is up (0.00073s latency).

PORT     STATE    SERVICE
1524/tcp filtered ingreslock
MAC Address: 12:35:01:1C:11:16 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.34 seconds

┌──(kali㉿kali)-[~]
└─$
```

Questa remediation ha dimostrato l'utilizzo di un controllo di rete per mitigare una vulnerabilità critica. Anche se il servizio risultava gestito da xinetd e non eliminabile in modo immediato, la sua sfruttabilità è stata efficacemente bloccata.

5.3 Vulnerabilità 3 – Apache Tomcat AJP Connector Exposure

Descrizione tecnica:
Il target esponeva il connettore Apache Tomcat AJP sulla porta 8009. L'esposizione di questo servizio può aumentare la superficie di attacco del sistema e rappresenta un rischio soprattutto in ambienti non segmentati o non protetti.
Obiettivo della remediation:
Disabilitare il servizio Tomcat per chiudere la porta 8009 e ridurre l'esposizione del sistema.
Attività eseguite:
• Identificazione del processo Tomcat attivo
• Verifica della porta 8009 in ascolto
• Individuazione del servizio init associato
• Arresto del servizio Tomcat
Comandi utilizzati:
sudo netstat -tulnp | grep 8009
ps aux | grep -i tomcat
ls /etc/init.d | grep -i tomcat
sudo /etc/init.d/tomcat5.5 stop
Verifica finale:
La remediation è stata considerata efficace quando la porta 8009 non risultava più in ascolto e il processo Tomcat non era più presente.
Figura 11: Tomcat attivo / porta 8009 aperta]

```
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep  8009
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN
4720/jsvc
```

Figura 12: servizio tomcat5.5 identificato]

```
msfadmin@metasploitable:~$ ls /etc/init.d | grep -i tomcat
tomcat5.5
```

Figura 13: Stop del servizio Tomcat e verifica finale –
porta 8009 chiusa / processo
assente

```
msfadmin@metasploitable:~$ sudo service tomcat5.5 stop
sudo: service: command not found
msfadmin@metasploitable:~$ sudo /etc/init.d/tomcat5.5 stop
 * Stopping Tomcat servlet engine tomcat5.5                    [ OK ]
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep 8009
msfadmin@metasploitable:~$ ps aux | grep -i tomcat
msfadmin  7418  0.0  0.1   3004   832 tty1     S+   22:00   0:00 grep -i tomcat
msfadmin@metasploitable:~$
```

Commento conclusivo sezione:
L'arresto di Tomcat ha consentito di eliminare l'esposizione del connettore AJP, riducendo ulteriormente la superficie di attacco del target.

5.4 Vulnerabilità 4 – PostgreSQL Exposed Service / Service Hardening

Descrizione tecnica:
Durante l'analisi dei servizi esposti è stato osservato PostgreSQL in ascolto sulla porta 5432. Pur non trattandosi necessariamente di una vulnerabilità autonoma nel senso classico, la presenza di servizi non necessari o eccessivamente esposti rappresenta comunque un rischio di sicurezza e contribuisce all'aumento della superficie di attacco.
Obiettivo della remediation:
Disabilitare PostgreSQL per rimuovere l'esposizione del servizio e migliorare l'hardening generale del target.
Attività eseguite:
• Identificazione del processo PostgreSQL
• Verifica della porta 5432 in ascolto
• Individuazione del servizio init corretto
• Arresto del database server PostgreSQL
Comandi utilizzati:
ps aux | grep postgres
sudo netstat -tulnp | grep 5432
ls /etc/init.d | grep postgres
sudo /etc/init.d/postgresql-8.3 stop
Verifica finale:
La remediation è stata verificata confermando che la porta 5432 non risultava più aperta e che non erano più presenti processi PostgreSQL attivi.
Figura 14: PostgreSQL attivo / porta 5432 aperta

```
Metasploitable
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep 443
tcp        0      0 0.0.0.0:5432            0.0.0.0:*               LISTEN
4443/postgres
tcp6       0      0 :::5432                 :::*                    LISTEN
4443/postgres
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep ssl
msfadmin@metasploitable:~$ _
```

Figura 15: servizio postgresql-8.3 identificato

```
Metasploitable
www-data  7093  0.0  0.4  10596  2236 ?        S    20:25   0:00 /usr/sbin/apac
e2 -k start
msfadmin  7443  0.0  0.1   3008   776 tty1     S+   22:03   0:00 grep apache
msfadmin@metasploitable:~$ ps aux | grep postgres
postgres  4443  0.0  0.9  41340  5072 ?        S    08:03   0:02 /usr/lib/postg
esql/8.3/bin/postgres -D /var/lib/postgresql/8.3/main -c config_file=/etc/postg
esql/8.3/main/postgresql.conf
postgres  4445  0.0  0.2  41340  1380 ?        Ss   08:03   0:47 postgres: writ
r process

postgres  4446  0.0  0.2  41340  1192 ?        Ss   08:03   0:30 postgres: wal
riter process

postgres  4447  0.0  0.2  41340  1388 ?        Ss   08:03   0:07 postgres: auto
acuum launcher process

postgres  4448  0.0  0.2  12660  1132 ?        Ss   08:03   0:04 postgres: stat
 collector process

msfadmin  7446  0.0  0.1   3004   760 tty1     R+   22:04   0:00 grep postgres
msfadmin@metasploitable:~$ ls /etc/innit.d | grep postgres
ls: cannot access /etc/innit.d: No such file or directory
msfadmin@metasploitable:~$ ls /etc/init.d | grep postgres
postgresql-8.3
```

16: stop del servizio PostgreSQL e verifica finale – porta 5432 chiusa / processo assente

```
Metasploitable
msfadmin@metasploitable:~$ sudo /etc/init.d/postgresql-8.3 stop
[sudo] password for msfadmin:
 * Stopping PostgreSQL 8.3 database server                          [ OK ]
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep 5432
msfadmin@metasploitable:~$ ps aux | grep postgres
msfadmin  7587  0.0  0.1   3004   768 tty1     R+   23:55   0:00 grep postgres
```

Commento conclusivo sezione:
Questa attività ha rafforzato il sistema eliminando un servizio esposto non essenziale per il laboratorio.

6. Considerazioni tecniche su firewall e strumenti di utilizzo:

Durante l'attività, pfSense non è stato necessario come componente obbligatoria del laboratorio. La traccia permetteva l'uso di regole firewall come misura di remediation, ma non richiedeva un firewall esterno specifico. È stato comunque dimostrato l'approccio di mitigazione di rete tramite iptables, applicando una regola firewall locale per bloccare la bind shell sulla porta 1524. Allo stesso modo, Wireshark non è stato necessario, poiché l'esercizio si concentrava sulla remediation delle vulnerabilità e sulla validazione tramite nuova scansione, piuttosto che sull'analisi packet-level del traffico.

7. Fase 3 – Scansione finale e confronto dei risultati:
Dopo le attività di remediation manuali sui servizi esposti, non è stata eseguita una nuova scansione completa tramite Nessus. La verifica è stata condotta tramite strumenti di sistema

(netstat, ps, nmap), confermando la chiusura delle porte vulnerabili e l'arresto dei servizi associati. In particolare:
* La porta 5900 (VNC) risulta chiusa.
* La porta 1524 (bind shell) risulta filtrata tramite firewall.
* La porta 8009 (Tomcat) non è più in ascolto.
* La porta 5432 (PostgreSQL) non è più esposta.

Questi risultati indicano una significativa riduzione della superficie di attacco del sistema target.

8. Confronto sintetico prima/dopo:

* VNC (porta 5900): inizialmente attivo, successivamente disabilitato.
* Bind Shell (porta 1524): inizialmente sfruttabile, successivamente filtrata via firewall.
* Tomcat AJP (porta 8009): inizialmente in ascolto, successivamente chiuso.
* PostgreSQL (porta 5432): inizialmente esposto, successivamente disabilitato.

9. Conclusione finale:

L'attività ha dimostrato un workflow completo di vulnerability assessment e remediation su un target appositamente vulnerabile. Utilizzando scansioni, enumerazione tecnica e interventi pratici di hardening, è stato possibile ridurre significativamente la superficie di attacco del sistema. Le remediation applicate hanno riguardato la disattivazione di servizi esposti non necessari e l'adozione di misure di mitigazione di rete per impedire lo sfruttamento diretto di servizi pericolosi. La scansione finale ha validato il miglioramento dello stato di sicurezza del target e dimostrato l'efficacia degli interventi implementati. Nel complesso, il laboratorio ha permesso di mettere in pratica competenze fondamentali in cybersecurity, tra cui vulnerability assessment, service enumeration, remediation operativa, verifica tecnica post-remediation e documentazione professionale dei risultati.